SE Lab 5: Static Code Analysis

Name: Venkata Srivaibhav Nukaraju

SRN: PES2UG24CS579

Section: 5 J

Course: UE24CS341A Software Engineering

1. Links

Assigned repository: https://github.com/SETAPESU26/L5_19_music_catalog

Script: music_catalog.py. The program stores songs in SQLite, rates popularity, picks a random song and saves playlists.

Three commits fix the findings of Bandit, Pylint and Flake8, one commit per tool.

Commit	Tool	Change
c549d7a	Bandit	Parameterised SQL, JSON instead of pickle, secrets.choice
5792ba0	Pylint	Docstrings, snake_case names, mutable default, bare except, main guard
5d9aea5	Flake8	Line wrapping, final reports, issue table, reflection

2. Issue Table

Issue	Type	Line(s)	Description	Fix Approach
SQL injection (B608)	Security, Medium	10	addSong builds the INSERT with % formatting, so a title such as x'); DROP TABLE songs;-- alters the query	Use ? placeholders and pass a parameter tuple
Unsafe pickle load (B301)	Security, Medium	33	pickle.loads runs arbitrary code from untrusted bytes	Store playlists as JSON with json.dumps and json.loads
Pickle import (B403)	Security, Low	1	Import of pickle flagged	Remove the import and use json
Weak random (B311)	Security, Low	17	random.choice is not a secure	Use secrets.choice

			generator	
Mutable default arg (W0102)	Bug	9	playlist=[] is shared across calls, so unrelated playlists mix	Default to None and create a new list in the function
Bare except (W0702, E722)	Bug	39	except: hides every error, including KeyboardInterrupt	Catch sqlite3.Error
Naming (C0103)	Style	9, 15, 28, 32, 36	camelCase function names break PEP 8	Rename to add_song, shuffle_pick, save_playlist, load_playlist, total_plays
Missing docstrings (C0114, C0116)	Style	1, 9, 15, 20, 28, 32, 36, 43	Module and functions have no docstring	Add one-line docstrings
Unnecessary else (R1705)	Style	22	else follows a return	Remove the else and de-indent
Ambiguous name (E741)	Style	47	Variable l looks like 1	Rename to loaded
Multiple statements (E701, C0321)	Style	48	if and print share one line	Put print on its own line
Line too long (E501, C0301)	Style	6, 10, 21, 49	Lines exceed 79 characters	Wrap the lines
F-string suggestion (C0209)	Style	10	% formatting on a regular string	Resolved by the parameterised query
Import-time run	Design	52	main() runs on import	Guard with if __name__ == "__main__":

3. Results

Tool	Before	After
Pylint score	4.57/10	10.00/10
Pylint messages	19	0
Bandit issues (Medium / Low)	2 / 2	0 / 0
Flake8 violations	7	0

The program prints the same output before and after the fixes, apart from the random song id.

The before and after reports are in the repository: before/ holds the first run and the root folder holds the final run.

4. Output Screenshots

The screenshots are rendered headless from the real command output, so the window focus stays unchanged.

Screenshot 1: Program run before the fixes

```
PES2UG24CS579@se-lab5:~/L5_19_music_catalog$ python music_catalog.py
multi-song playlist
popular niche 1 290
```

Screenshot 2: Pylint before the fixes

```
PES2UG24CS579@se-lab5:~/L5_19_music_catalog$ pylint music_catalog.py
************* Module music_catalog
music_catalog.py:10:0: C0301: Line too long (109/100) (line-too-long)
music_catalog.py:1:0: C0114: Missing module docstring (missing-module-docstring)
music_catalog.py:9:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:9:0: C0103: Function name "addSong" doesn't conform to snake_case naming style (invalid-name)
music_catalog.py:9:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
music_catalog.py:10:17: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
music_catalog.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:15:0: C0103: Function name "shufflePick" doesn't conform to snake_case naming style (invalid-name)
music_catalog.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:22:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-
else-return)
music_catalog.py:28:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:28:0: C0103: Function name "savePlaylist" doesn't conform to snake_case naming style (invalid-name)
music_catalog.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:32:0: C0103: Function name "loadPlaylist" doesn't conform to snake_case naming style (invalid-name)
music_catalog.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:36:0: C0103: Function name "totalPlays" doesn't conform to snake_case naming style (invalid-name)
music_catalog.py:39:4: W0702: No exception type(s) specified (bare-except)
music_catalog.py:43:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:48:19: C0321: More than one statement on a single line (multiple-statements)

-----------------------------------
Your code has been rated at 4.57/10
```

Screenshot 3: Bandit before the fixes

```
PES2UG24CS579@se-lab5:~/L5_19_music_catalog$ bandit -r music_catalog.py
Run started:2026-10-27 05:22:41.242608+00:00

Test results:
>> Issue: [B403:blacklist] Consider possible security implications associated with pickle module.
   Severity: Low   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b403-import-pickle
   Location: ./music_catalog.py:1:0
1       import pickle
2       import random
3       import sqlite3

--------------------------------------------------
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: ./music_catalog.py:10:17
9       def addSong(title, artist, plays=0, playlist=[]):
10          conn.execute("INSERT INTO songs (title, artist, plays) VALUES ('%s', '%s', %d)" % (title, artist, plays))
11          playlist.append(title)

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: ./music_catalog.py:17:11
16          ids = [r[0] for r in conn.execute("SELECT id FROM songs")]
17          return random.choice(ids)
18

--------------------------------------------------
>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data,
possible security issue.
   Severity: Medium   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle
   Location: ./music_catalog.py:33:11
32      def loadPlaylist(blob):
33          return pickle.loads(blob)
34

--------------------------------------------------

Code scanned:
        Total lines of code: 35
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 2
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 3
Files skipped (0):
```

Screenshot 4: Flake8 before the fixes

```
PES2UG24CS579@se-lab5:~/L5_19_music_catalog$ flake8 music_catalog.py
music_catalog.py:6:80: E501 line too long (99 > 79 characters)
music_catalog.py:10:80: E501 line too long (109 > 79 characters)
music_catalog.py:21:80: E501 line too long (86 > 79 characters)
music_catalog.py:39:5: E722 do not use bare 'except'
music_catalog.py:47:5: E741 ambiguous variable name 'l'
music_catalog.py:48:18: E701 multiple statements on one line (colon)
music_catalog.py:49:80: E501 line too long (83 > 79 characters)
```

Screenshot 5: Program run after the fixes

```
PES2UG24CS579@se-lab5:~/L5_19_music_catalog$ python music_catalog.py
multi-song playlist
popular niche 1 290
```

Screenshot 6: Pylint after the fixes

```
PES2UG24CS579@se-lab5:~/L5_19_music_catalog$ pylint music_catalog.py
-----------------------------------
Your code has been rated at 10.00/10
```

Screenshot 7: Bandit after the fixes

```
PES2UG24CS579@se-lab5:~/L5_19_music_catalog$ bandit -r music_catalog.py
Run started:2026-10-27 05:22:41.939791+00:00

Test results:
        No issues identified.

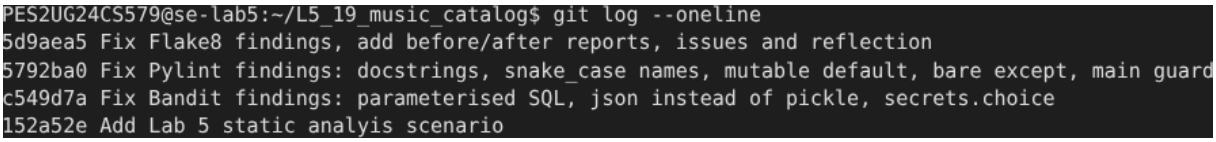
Code scanned:
        Total lines of code: 55
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

Screenshot 8: Flake8 after the fixes

```
PES2UG24CS579@se-lab5:~/L5_19_music_catalog$ flake8 music_catalog.py
exit code 0
```

Screenshot 9: Git log with the three fix commits



5. Reflection

1. Which issues did the tools find that manual inspection could miss?

Bandit flagged the pickle load and the string-built SQL at once. Pylint found the shared mutable default `playlist=[]`. A quick read shows working output, so these defects stay hidden until a second call or hostile input exposes them.

2. Which tool gave the most useful findings?

Bandit gave the most serious findings, because it reported two Medium security issues. Pylint gave the widest coverage and a score. Flake8 reported only style, but its rules are strict and fast to apply.

3. Were there false positives or low-value findings?

The Low findings for the `pickle` import and for `random` need context. A music shuffle is not a security use. The change to `secrets.choice` costs nothing, so the fix stays. The docstring and naming messages improve readability but do not change behaviour.

4. How does static analysis change the development workflow?

The tools run in seconds and give a repeatable check before review. A team can run them in a commit hook or in continuous integration. Reviewers then spend time on logic instead of style. The tools do not replace tests, because they cannot prove that the program is correct.